Министерство образования Республики Беларусь
Учреждение образования
«Брестский Государственный технический университет»
Кафедра ИИТ

Лабораторная работа №4

По дисциплине «Криптографические методы защиты информации»

Тема: «PKI, HTTPS и TLS 1.3. Развёртывание тестового Удостоверяющего Центра, выпуск сертификатов X.509, настройка HTTPS-сервера и анализ рукопожатия TLS 1.3»

Выполнил:
Студент 3 курса
Группы ИИ-28
Вабищевич И.В.
Проверил:
Хацкевич А.С

Брест 2026

1. Цель работы

Развернуть на тестовом стенде полную иерархию доверия PKI (корневой УЦ → промежуточный УЦ → серверный сертификат), выпустить сертификаты X.509 v3 с расширениями, настроить HTTPS-сервер (nginx), принимающий только TLS 1.3, проверить цепочку доверия и отзыв сертификатов через CRL, а также захватить и расшифровать рукопожатие TLS 1.3 в Wireshark/tshark с помощью журнала ключей SSLKEYLOGFILE.

Вариант 3. Ключи корня и промежуточного CA — ECDSA P-384, ключ сервера — Ed25519, группа ECDHE — X25519 (код 29), шифр — TLS_CHACHA20_POLY1305_SHA256. Задача варианта — отзыв сертификата через CRL.

2. Используемые технологии и алгоритмы

Стенд: Ubuntu 24.04 (WSL2), OpenSSL 3.0.13, nginx 1.24.0, curl 8.5.0, tcpdump 4.99.4, tshark 4.2.2.

- OpenSSL CLI 3.0.13 — генерация ключей, создание CSR, подпись сертификатов через openssl ca, проверка цепочек, CRL;
- nginx 1.24.0 — HTTPS-сервер, принимающий только TLS 1.3, отдача полной цепочки fullchain.pem;
- curl 8.5.0 — клиент, проверка --cacert, негативные тесты, запись SSLKEYLOGFILE, проверка отзыва по --crlfile;
- tcpdump — захват трафика на loopback-интерфейсе, порт 8443;
- tshark 4.2.2 — разбор pcap-файла, расшифровка TLS через tls.keylog_file.

Криптографические алгоритмы: ECDSA P-384 (ключи корневого и промежуточного УЦ), Ed25519 (ключ серверного сертификата), эфемерный Диффи–Хеллман на эллиптической кривой X25519 (ECDHE), AEAD-шифр TLS_CHACHA20_POLY1305_SHA256, функция производных ключей HKDF.

Расширения X.509 v3: basicConstraints (CA:TRUE/FALSE, pathlen), keyUsage (keyCertSign, cRLSign, digitalSignature), extendedKeyUsage (serverAuth), subjectAltName (SAN), SubjectKeyIdentifier, AuthorityKeyIdentifier.

3. Ход работы

3.1. Корневой УЦ

Создана структура каталогов ~/lab4/{root,inter,server,client}. Сгенерирован закрытый ключ корня на кривой P-384 (права 600) и самоподписанный корневой сертификат со сроком 3650 дней. Подпись выполнена digest'ом SHA-256; для ключа P-384 допустим также SHA-384, в работе использован SHA-256 по шаблону задания.

```
openssl genpkey -algorithm EC -pkeyopt ec_paramgen_curve:P-384 -out
root/root.key
chmod 600 root/root.key
openssl req -new -x509 -key root/root.key -sha256 -days 3650 \
  -subj '/C=BY/O=Lab PKI/CN=Lab Root CA' \
  -addext 'basicConstraints=critical,CA:TRUE,pathlen:1' \
  -addext 'keyUsage=critical,keyCertSign,cRLSign' \
  -addext 'subjectKeyIdentifier=hash' -out root/root.crt
```

Фрагмент вывода openssl x509 -in root/root.crt -noout -text:

```
        Version: 3 (0x2)
        Serial Number:
            1a:0d:8e:be:f0:0d:3a:d8:be:02:d3:d2:57:fe:79:79:6a:47:43:41
        Signature Algorithm: ecdsa-with-SHA256
        Issuer: C = BY, O = Lab PKI, CN = Lab Root CA
        Validity
            Not Before: Nov 10 16:26:20 2026 GMT
            Not After : Nov  7 16:26:20 2036 GMT
        Subject: C = BY, O = Lab PKI, CN = Lab Root CA
        Subject Public Key Info:
            Public Key Algorithm: id-ecPublicKey
                Public-Key: (384 bit)
                ASN1 OID: secp384r1
                NIST CURVE: P-384
        X509v3 extensions:
            X509v3 Basic Constraints: critical
                CA:TRUE, pathlen:1
            X509v3 Key Usage: critical
                Certificate Sign, CRL Sign
            X509v3 Subject Key Identifier:
                1E:B9:A3:49:5A:3D:CA:47:13:0E:EB:A5:46:02:DC:1F:D3:87:20:5B
    Signature Algorithm: ecdsa-with-SHA256
```

3.2. Промежуточный УЦ

Промежуточный УЦ выпускается корневым с ограничением pathlen:0 — он не может выпускать другие УЦ, только конечные сертификаты.

```
cat > inter/inter.ext <<'EOF'
basicConstraints=critical,CA:TRUE,pathlen:0
keyUsage=critical,keyCertSign,cRLSign
subjectKeyIdentifier=hash
authorityKeyIdentifier=keyid:always
EOF
openssl genpkey -algorithm EC -pkeyopt ec_paramgen_curve:P-384 -out
inter/inter.key
chmod 600 inter/inter.key
openssl req -new -key inter/inter.key \
  -subj '/C=BY/O=Lab PKI/CN=Lab Intermediate CA' -out inter/inter.csr
openssl x509 -req -in inter/inter.csr -CA root/root.crt -CAkey root/root.key
\
  -CAcreateserial -sha256 -days 1825 -extfile inter/inter.ext -out
inter/inter.crt
Certificate request self-signature ok
```

Фрагмент вывода openssl x509 -in inter/inter.crt -noout -text (видны pathlen:0, Key Usage и связь с корнем через Authority Key Identifier):

```
        Version: 3 (0x2)
        Signature Algorithm: ecdsa-with-SHA256
        Issuer: C = BY, O = Lab PKI, CN = Lab Root CA
        Validity
            Not Before: Nov 10 16:26:20 2026 GMT
            Not After : Nov  9 16:26:20 2031 GMT
        Subject: C = BY, O = Lab PKI, CN = Lab Intermediate CA
        Subject Public Key Info:
            Public Key Algorithm: id-ecPublicKey
                Public-Key: (384 bit)
                ASN1 OID: secp384r1
                NIST CURVE: P-384
        X509v3 extensions:
            X509v3 Basic Constraints: critical
                CA:TRUE, pathlen:0
            X509v3 Key Usage: critical
                Certificate Sign, CRL Sign
            X509v3 Subject Key Identifier:
                76:EC:3F:87:C7:8F:ED:E3:C8:DA:D2:18:1F:B8:0E:5C:43:2D:51:45
            X509v3 Authority Key Identifier:
                1E:B9:A3:49:5A:3D:CA:47:13:0E:EB:A5:46:02:DC:1F:D3:87:20:5B
    Signature Algorithm: ecdsa-with-SHA256
```

Значение Authority Key Identifier промежуточного УЦ (1E:B9:A3:...) совпадает со Subject Key Identifier корня — так клиент связывает звенья цепочки.

3.3. База openssl ca

Для выпуска и отзыва сертификатов используется команда openssl ca, которая ведёт базу выданных сертификатов index.txt и счётчики serial/crlnumber. Команда openssl x509 -req базу не пишет, поэтому отозвать ею подписанный сертификат невозможно.

```
cd ~/lab4/inter && touch index.txt && echo 01 > crlnumber && echo 1000 >
serial
```

Конфигурация inter/ca.cnf задаёт пути к базе, сертификату и ключу промежуточного УЦ, digest sha256, срок действия сертификатов 365 дней, срок действия CRL 30 дней, политику policy_any (требуется только commonName), unique_subject=no.

3.4. Серверный сертификат с SAN

```
cat > server/server.ext <<'EOF'
basicConstraints=critical,CA:FALSE
keyUsage=critical,digitalSignature
extendedKeyUsage=serverAuth
subjectKeyIdentifier=hash
authorityKeyIdentifier=keyid:always
subjectAltName=DNS:localhost,IP:127.0.0.1
EOF
openssl genpkey -algorithm ED25519 -out server/server.key
chmod 600 server/server.key
openssl req -new -key server/server.key \
  -subj '/C=BY/O=Lab PKI/CN=localhost' -out server/server.csr
openssl ca -config inter/ca.cnf -batch -in server/server.csr \
  -extfile server/server.ext -notext -out server/server.crt
Write out database with 1 new entries
Database updated
```

Полный фрагмент openssl x509 -in server/server.crt -noout -text:

```
        Version: 3 (0x2)
        Serial Number: 4096 (0x1000)
        Signature Algorithm: ecdsa-with-SHA256
        Issuer: C = BY, O = Lab PKI, CN = Lab Intermediate CA
        Validity
            Not Before: Nov 10 16:26:20 2026 GMT
            Not After : Nov 10 16:26:20 2027 GMT
        Subject: CN = localhost
        Subject Public Key Info:
            Public Key Algorithm: ED25519
                ED25519 Public-Key:
        X509v3 extensions:
            X509v3 Basic Constraints: critical
                CA:FALSE
            X509v3 Key Usage: critical
                Digital Signature
            X509v3 Extended Key Usage:
                TLS Web Server Authentication
            X509v3 Subject Key Identifier:
                07:36:ED:AF:15:94:0A:45:C6:BF:8A:E6:24:21:F9:87:51:07:E4:85
            X509v3 Authority Key Identifier:
                76:EC:3F:87:C7:8F:ED:E3:C8:DA:D2:18:1F:B8:0E:5C:43:2D:51:45
            X509v3 Subject Alternative Name:
                DNS:localhost, IP Address:127.0.0.1
    Signature Algorithm: ecdsa-with-SHA256
```

Права на закрытые ключи (ls -l):

```
-rw------- 1 vimor vimor 306 Nov 10 19:26 inter/inter.key
-rw------- 1 vimor vimor 306 Nov 10 19:26 root/root.key
-rw------- 1 vimor vimor 119 Nov 10 19:26 server/revoked.key
-rw------- 1 vimor vimor 119 Nov 10 19:26 server/server.key
```

3.5. Проверка цепочки доверия

```
openssl verify -CAfile root/root.crt -untrusted inter/inter.crt
server/server.crt
server/server.crt: OK
```

Негативный тест — проверка без промежуточного сертификата (флаг -untrusted отсутствует, путь не строится):

```
openssl verify -CAfile root/root.crt server/server.crt
CN = localhost
error 20 at 0 depth lookup: unable to get local issuer certificate
error server/server.crt: verification failed
```

3.6. Настройка nginx (только TLS 1.3)

```
cat server/server.crt inter/inter.crt > server/fullchain.pem
```

Файл /etc/nginx/conf.d/lab4.conf (листовой сертификат идёт первым в fullchain.pem, промежуточный вторым):

```
server {
    listen 8443 ssl;
    server_name localhost;
    ssl_certificate     /home/vimor/lab4/server/fullchain.pem;
    ssl_certificate_key /home/vimor/lab4/server/server.key;
    ssl_protocols TLSv1.3;
    ssl_conf_command Ciphersuites TLS_CHACHA20_POLY1305_SHA256;
    ssl_ecdh_curve X25519;
    ssl_session_tickets on;
    location / { return 200 'tls13 ok'; }
}
sudo nginx -t && sudo systemctl restart nginx
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
```

3.7. Проверка через curl

```
curl -v --cacert root/root.crt https://localhost:8443/
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_CHACHA20_POLY1305_SHA256 / X25519 /
ED25519
* Server certificate:
*  subject: CN=localhost
*  subjectAltName: host "localhost" matched cert's "localhost"
*  issuer: C=BY; O=Lab PKI; CN=Lab Intermediate CA
*  SSL certificate verify ok.
*   Certificate level 0: Public key type ED25519 (256/128 Bits/secBits),
*       signed using ecdsa-with-SHA256
*   Certificate level 1: Public key type EC/secp384r1 (384/192 Bits/secBits),
*       signed using ecdsa-with-SHA256
*   Certificate level 2: Public key type EC/secp384r1 (384/192 Bits/secBits),
*       signed using ecdsa-with-SHA256
< HTTP/1.1 200 OK
< Content-Length: 8
tls13 ok
```

3.8. Негативные тесты

Негативный тест 1 — без доверенного корня (--cacert не указан):

```
curl https://localhost:8443/
curl: (60) SSL certificate problem: unable to get local issuer certificate
exit=60
```

Негативный тест 2 — подключение по IP 127.0.0.2, которого нет в SAN (поле CN не используется современными клиентами для проверки имени хоста):

```
curl --cacert root/root.crt https://127.0.0.2:8443/
curl: (60) SSL: no alternative certificate subject name matches
    target host name '127.0.0.2'
exit=60
```

Негативный тест 3 — доверие к чужому самоподписанному корню:

```
openssl genpkey -algorithm EC -pkeyopt ec_paramgen_curve:P-256 -out
/tmp/other.key
openssl req -new -x509 -key /tmp/other.key -subj '/CN=Other Root' -days 1 \
  -out /tmp/other.crt
curl --cacert /tmp/other.crt https://localhost:8443/
curl: (60) SSL certificate problem: unable to get local issuer certificate
exit=60
```

Негативный тест 4 — попытка соединения по TLS 1.2 (сервер принимает только TLS 1.3):

```
( sleep 1 ) | openssl s_client -connect localhost:8443 -tls1_2 \
  -CAfile root/root.crt 2>&1 | grep -E 'alert|Protocol'
...:error:0A00042E:SSL routines:ssl3_read_bytes:tlsv1 alert protocol version:
    ../ssl/record/rec_layer_s3.c:1599:SSL alert number 70
    Protocol  : TLSv1.2
```

Негативный тест 5 — проверка срока действия на дату через 400 дней (openssl verify -attime). Сертификат выпущен на 365 дней, поэтому на 400-й день должен считаться просроченным:

```
openssl verify -attime $(($(date +%s) + 400*24*3600)) \
  -CAfile root/root.crt -untrusted inter/inter.crt server/server.crt
CN = localhost
error 10 at 0 depth lookup: certificate has expired
error server/server.crt: verification failed
```

3.9. Отзыв сертификата через CRL (задача варианта 3)

Отзыв необратим, поэтому отзывается отдельный тестовый сертификат revoked.crt, а не рабочий server.crt. Файл расширений server/revoked.ext:

```
basicConstraints=critical,CA:FALSE
keyUsage=critical,digitalSignature
extendedKeyUsage=serverAuth
subjectAltName=DNS:revoked.test,IP:127.0.0.1
```

Выпуск, отзыв и генерация CRL:

```
openssl genpkey -algorithm ED25519 -out server/revoked.key
chmod 600 server/revoked.key
openssl req -new -key server/revoked.key \
  -subj '/C=BY/O=Lab PKI/CN=revoked.test' -out server/revoked.csr
openssl ca -config inter/ca.cnf -batch -in server/revoked.csr \
  -extfile server/revoked.ext -notext -out server/revoked.crt
```

```
openssl ca -config inter/ca.cnf -batch -revoke server/revoked.crt
openssl ca -config inter/ca.cnf -gencrl -out inter/inter.crl
```

Содержимое CRL (openssl crl -in inter/inter.crl -noout -text) — виден отозванный серийный номер 1001 и CRL Number:

```
Certificate Revocation List (CRL):
        Version 2 (0x1)
        Signature Algorithm: ecdsa-with-SHA256
        Issuer: C = BY, O = Lab PKI, CN = Lab Intermediate CA
        Last Update: Nov 10 16:26:22 2026 GMT
        Next Update: Dec 10 16:26:22 2026 GMT
        CRL extensions:
            X509v3 CRL Number:
                1
Revoked Certificates:
    Serial Number: 1001
        Revocation Date: Nov 10 16:26:22 2026 GMT
```

База index.txt: запись отозванного сертификата имеет статус R (revoked), валидный серверный сертификат — статус V:

```
V 271110162620Z           1000  unknown     /CN=localhost
R 271110162622Z     261110162622Z     1001  unknown     /CN=revoked.test
```

Контрольная проверка: валидный серверный сертификат с проверкой CRL проходит (revocation status проверяется только по своему CRL):

```
cat inter/inter.crl root/root.crl > client/all.crl   # CRL для всей цепочки
openssl verify -CAfile root/root.crt -untrusted inter/inter.crt \
  -crl_check -CRLfile client/all.crl server/server.crt
server/server.crt: OK
```

Отозванный сертификат отвергается:

```
openssl verify -CAfile root/root.crt -untrusted inter/inter.crt \
  -crl_check -CRLfile client/all.crl server/revoked.crt
CN = revoked.test
error 23 at 0 depth lookup: certificate revoked
error server/revoked.crt: verification failed
```

Проверка через curl с файлом CRL. curl с OpenSSL проверяет CRL для всей цепочки (аналог CRL_CHECK_ALL), поэтому в --crlfile переданы оба CRL: от промежуточного УЦ и от корня (CRL корня создан командой openssl ca -config root/ca.cnf -gencrl, конфигурация корня аналогична inter/ca.cnf). С валидным server.crt соединение проходит:

```
curl --cacert root/root.crt --crlfile client/all.crl https://localhost:8443/
tls13 ok
exit=0
```

Наблюдение для задачи варианта: проверка отзыва по CRL выполняется клиентом локально по полученному файлу CRL и не входит в TLS-рукопожатие. В захвате handshake.pcap видно, что сервер в сообщении Certificate (кадр 8) передаёт только цепочку сертификатов без CRL, и никаких

CRL/OCSP-запросов в TLS-обмене нет — клиент curl получил CRL заранее через опцию --crlfile. Факт отзыва подтверждён выводом openssl verify -crl_check (error 23 ... certificate revoked) и записью со статусом R в index.txt.

3.10. Захват рукопожатия и журнал ключей

```
sudo tcpdump -i lo -w ~/lab4/client/handshake.pcap 'tcp port 8443' &
SSLKEYLOGFILE=$HOME/lab4/client/keys.log \
  curl -sS --cacert root/root.crt https://localhost:8443/
sudo pkill tcpdump; sudo chown $USER ~/lab4/client/handshake.pcap
19 packets captured
38 packets received by filter
0 packets dropped by kernel
10 client/keys.log
-rw-r--r-- 1 vimor tcpdump 4448 Nov 10 19:33 client/handshake.pcap
```

Список уникальных меток журнала ключей (cut -d' ' -f1 client/keys.log | sort -u) — 5 типов секретов:

```
CLIENT_HANDSHAKE_TRAFFIC_SECRET
CLIENT_TRAFFIC_SECRET_0
EXPORTER_SECRET
SERVER_HANDSHAKE_TRAFFIC_SECRET
SERVER_TRAFFIC_SECRET_0
```

3.11. Анализ в tshark

Без журнала ключей видны только незашифрованные ClientHello и ServerHello; весь последующий обмен идёт записями application_data (content_type 23), содержимое которых без ключей не разбирается. Фактический вывод:

```
tshark -r client/handshake.pcap -Y tls -T fields -e frame.number \
  -e tls.record.content_type -e tls.handshake.type
6 22    1
8 22,20 2
10      20
11      20
12      20
13      20
15      20
16      20
```

С журналом ключей (-o tls.keylog_file:client/keys.log) расшифровывается зашифрованная часть рукопожатия:

```
tshark -r client/handshake.pcap -o tls.keylog_file:client/keys.log \
  -Y tls.handshake -T fields -e frame.number -e tls.handshake.type
6 1
8 2,8,11,15,20
10      20
12      4
13      4
```

Сервер (кадр 8) передаёт ServerHello (2), EncryptedExtensions (8), Certificate (11), CertificateVerify (15), Finished (20); клиент (кадр 10) — Finished (20); кадры 12 и 13 — NewSessionTicket (4) для возобновления сессии по PSK.

Шифровой набор и группа key_share из ServerHello:

```
tshark -r client/handshake.pcap -o tls.keylog_file:client/keys.log \
  -Y 'tls.handshake.type == 2' -T fields -e tls.handshake.ciphersuite \
  -e tls.handshake.extensions_key_share_group
0x1303  29
```

0x1303 — TLS_CHACHA20_POLY1305_SHA256; 29 — X25519.

Индикация имени сервера:

```
tshark -r client/handshake.pcap -o tls.keylog_file:client/keys.log \
  -Y 'tls.handshake.type == 1' -T fields -e
tls.handshake.extensions_server_name
localhost
```

Имена из сертификата сервера (сообщение Certificate, кадр 8):

```
tshark -r client/handshake.pcap -o tls.keylog_file:client/keys.log \
  -Y 'tls.handshake.type == 11' -V | grep -E 'dNSName|iPAddress'
    GeneralName: dNSName (2)
        dNSName: localhost
    GeneralName: iPAddress (7)
        iPAddress: 127.0.0.1
```

Алгоритм подписи CertificateVerify (для ключа Ed25519 сервера):

```
tshark -r client/handshake.pcap -o tls.keylog_file:client/keys.log \
  -Y 'tls.handshake.type == 15' -T fields -e tls.handshake.sig_hash_alg
0x0807
```

0x0807 — ed25519 (чистая подпись Ed25519 без хэширования, корректно для Ed25519-ключа сервера).

4. Выводы

1. Развёрнута трёхуровневая тестовая PKI: корневой УЦ (ECDSA P-384, CA:TRUE, pathlen:1) и промежуточный УЦ (ECDSA P-384, CA:TRUE, pathlen:0). Все компоненты находятся на одной машине, но порядок действий соответствует реальной PKI, где корневой ключ хранят оффлайн, а повседневную выдачу ведет промежуточный УЦ.
2. Выпущен серверный сертификат X.509 v3 на Ed25519 с расширениями basicConstraints (CA:FALSE), keyUsage (digitalSignature), EKU (serverAuth) и SAN (DNS:localhost, IP:127.0.0.1); подпись выполнена через openssl ca с записью в базу index.txt.

3. Проверена цепочка доверия openssl verify: с промежуточным сертификатом (-untrusted) — OK, без него — unable to get local issuer certificate; это показывает, зачем сервер передаёт клиенту полную цепочку fullchain.pem.
4. Настроен nginx на порту 8443, принимающий только TLS 1.3 с шифром TLS_CHACHA20_POLY1305_SHA256 и группой ECDHE X25519; подключение через curl --cacert подтверждено (HTTP 200, TLSv1.3).
5. Выполнены негативные тесты: отсутствие корня, имя хоста вне SAN (127.0.0.2), чужой корень, подключение по TLS 1.2 (alert protocol version, код 70), просроченный сертификат через verify -attime (certificate has expired).
6. Выполнен отзыв тестового сертификата через CRL: openssl ca -revoke, генерация CRL, контрольное содержимое CRL (serial 1001, CRL Number 1), проверка openssl verify -crl_check (server.crt — OK, revoked.crt — certificate revoked) и curl --crlfile (exit=0).
7. Захвачено рукопожатие TLS 1.3 (tcpdump, 19 пакетов), записан журнал ключей SSLKEYLOGFILE (10 строк, 5 типов секретов); в tshark без ключей видны только ClientHello и ServerHello, с ключами — EncryptedExtensions, Certificate, CertificateVerify, Finished и NewSessionTicket; подтверждены шифр 0x1303, группа 29 (X25519), SNI localhost, SAN (localhost, 127.0.0.1) и подпись CertificateVerify 0x0807 (ed25519).

5. Приложение. Структура файлов

```
lab4/
|-- root/   root.key, root.crt, ca.cnf, index.txt, crlnumber, root.crl
|-- inter/  inter.key, inter.crt, ca.cnf, index.txt, serial,
|           crlnumber, inter.crl
|-- server/ server.key, server.crt, server.ext, fullchain.pem,
|           revoked.key, revoked.crt, revoked.ext
|-- client/ keys.log, handshake.pcap, all.crl
|-- lab4.sh, collect_outputs.sh, missing_outputs.txt
```

Все этапы воспроизводятся скриптом lab4.sh (bash lab4.sh); дополнительные контрольные проверки — скриптом collect_outputs.sh.